

CRYPTOGRAPHIC VULNERABILITY MANAGEMENT PROCESS

Programme	Enterprise Cryptographic Risk Management Program
Phase	Phase 4 - Crypto Vulnerability Management Process
Document Owner	Cryptography Security Analyst
Scope	Enterprise Cryptographic Assets
Standard	NIST SP 800-57 (Key Management Recommendation)
Version	1.0
Date	04 June 2026
Status	For Internal Review

Table of Contents

1. Purpose & Scope
2. Vulnerability Intake Sources
3. 6-Stage Lifecycle
4. Service Level Agreements (SLAs)
5. Roles & Responsibilities
6. Escalation Procedure
7. Process KPIs
8. Document Control

SECTION 1

Purpose & Scope

This document defines the Cryptographic Vulnerability Management Process for the enterprise. It establishes a structured, repeatable approach for identifying, assessing, remediating and closing cryptographic vulnerabilities across the organisation's certificate estate, key stores, algorithms and cryptographic libraries.

The process ensures that cryptographic risks are managed in a timely, accountable and auditable manner - aligned to NIST SP 800-57 (Recommendation for Key Management) and supporting the organisation's broader information security management objectives.

Scope

In Scope	Out of Scope
X.509 Digital Certificates	Application-level encryption logic
Cryptographic Key Stores and HSMs	Network firewall rule management
Cryptographic Algorithms in use (RSA, ECC, DSA)	Physical security controls
TLS/SSL Protocol configurations	Third-party vendor SLA management
PKI Infrastructure (CAs, RAs, OCSP)	Non-cryptographic vulnerabilities

SECTION 2

Vulnerability Intake Sources

Cryptographic vulnerabilities may be identified from three primary intake sources. All sources feed into the same 6-stage lifecycle regardless of origin.

Source	Description	Example
Internal Scanning	Automated certificate inventory tool detects expired certificates, weak key sizes or deprecated algorithms during scheduled scans.	Phase 1 scanner flags RSA-1024 certificate
Standards Update	NIST or ENISA publishes a deprecation notice, making a currently in-use algorithm or key size non-compliant overnight.	NIST deprecates SHA-1 - all SHA-1 certs become non-compliant
Security Incident	A breach, exploit or penetration test reveals a weakness in a cryptographic algorithm or certificate deployed in the environment.	Man-in-the-middle attack exploits expired certificate

SECTION 3

6-Stage Vulnerability Management Lifecycle

All cryptographic vulnerabilities follow a structured 6-stage lifecycle from identification through to formal closure. Each stage has defined inputs, outputs, owners and timelines.

STAGE 01 - Identification & Intake

Owner:
Crypto Risk Analyst

Description	The vulnerability is identified from one of the three intake sources. A formal vulnerability ticket is raised and documented with full details - source of discovery, affected asset, algorithm or certificate details, and an initial description. A unique identifier (e.g. CVULN-001) is assigned.
Input	Inventory scan results / NIST advisory / Incident report
Output	Vulnerability Ticket with unique ID

STAGE 02 - Assessment & Prioritisation

Owner: Crypto Risk
Analyst

Description	The vulnerability is assessed for business impact, exploitability, compliance implications and asset criticality. A risk severity rating - Critical, High, Medium or Low - is assigned based on the assessment. The SLA clock starts from this point.
Input	Vulnerability Ticket
Output	Risk Rating, SLA Target, Risk Register Entry

STAGE 03 - Assignment & Response Planning

Owner:
Crypto Risk Analyst

Description	The vulnerability is formally assigned to the Asset Owner and PKI Team. A remediation plan is agreed - including technical approach, timeline and resources. The CISO is notified for all Critical and High findings.
Input	Risk Rating, SLA Target
Output	Remediation Plan, Stakeholder Notification

**STAGE 04 -
Remediation**
Owner: PKI Team

Description	The PKI Team executes the agreed remediation plan - revoking expired or weak certificates, verifying revocation via CRL and OCSP, generating new CSRs with compliant key sizes, and deploying replacement certificates across all affected systems.
Input	Remediation Plan
Output	Remediated Asset, Updated Certificate or Key

**STAGE 05 -
Verification &
Testing** Owner:
Crypto Risk Analyst

Description	The Crypto Risk Analyst re-runs the Phase 1 certificate inventory scan and reviews the Phase 2 posture dashboard to confirm the vulnerability no longer appears. Certificate status, key strength and algorithm compliance are verified against NIST SP 800-57.
Input	Remediated Asset
Output	Verified Inventory Scan, Dashboard KRIs Green

**STAGE 06 - Closure
& Reporting**
Owner: Crypto Risk
Analyst

Description	The vulnerability ticket is formally closed. A closure report is distributed to all stakeholders - Asset Owner, CISO and PKI Team - documenting what was identified, what action was taken, whether the SLA was met, and lessons learned.
Input	Verified Scan Results
Output	Closure Report, Updated Risk Register, KPI Update

SECTION 4

Service Level Agreements (SLAs)

The following SLA targets define the maximum time permitted from vulnerability identification to completed remediation, based on risk severity and aligned to industry best practice.

Severity	SLA Target	Escalation Trigger	Consequence of Breach
Critical	1 to 3 days	Day 1 - immediate CISO notification	Mandatory escalation, emergency change process invoked
High	7 days	Day 5 - CISO notified of delay	Formal escalation report issued to CISO
Medium	30 to 45 days	Day 30 - progress review required	Risk acceptance required from Asset Owner
Low	1 to 3 months	Monthly progress check	Documented exception with agreed extended timeline

SECTION 5

Roles & Responsibilities

The following roles are defined for the cryptographic vulnerability management process. Each role has clear accountability at each stage of the lifecycle.

Role	Responsibility	Stage Involvement
Cryptography Security Analyst	Primary process owner. Identifies, documents and assesses vulnerabilities. Assigns severity, tracks remediation progress, verifies closure and produces all reports.	All stages (1-6)
Asset Owner	Business or technical owner of the affected system. Approves remediation timelines, accepts residual risk where applicable and ensures their team supports implementation.	Stages 3, 4, 6
CISO	Executive stakeholder. Approves risk acceptance for Critical and High findings, receives formal escalations and signs off closure for high-severity vulnerabilities.	Stages 3, 6 (Critical/High)
PKI Team	Technical implementers responsible for certificate and key lifecycle. Execute the remediation plan - revoking, replacing and deploying certificates. Confirm operational completion.	Stage 4, 5

SECTION 6

Escalation Procedure

If a vulnerability is not remediated within the defined SLA, or if an Asset Owner refuses to remediate, the following escalation procedure applies.

SLA Breach Escalation

Step	Action	Owner	Timeline
1	SLA breach detected. Crypto Risk Analyst documents the missed deadline and reasons for delay.	Crypto Risk Analyst	Immediately on breach
2	Formal escalation report prepared - includes vulnerability details, missed SLA, business risk exposure and recommended action.	Crypto Risk Analyst	Within 24 hours
3	Escalation report submitted to CISO with request for mandate or formal risk acceptance.	Crypto Risk Analyst	Within 24 hours
4	CISO reviews and either mandates immediate remediation or formally accepts the risk with documented justification.	CISO	Within 48 hours
5	Decision documented in risk register and communicated to all stakeholders.	Crypto Risk Analyst	Within 48 hours

Risk Acceptance

Where the CISO formally accepts a risk rather than mandating remediation, the following must be documented in the risk register: the risk accepted, the business justification, the accepting authority (CISO name and date), any compensating controls in place, and the scheduled review date. Risk acceptance is not permanent and must be reviewed at least every 90 days.

SECTION 7

Process KPIs

The following KPIs measure the effectiveness of the cryptographic vulnerability management process. These are reported monthly to the CISO and security leadership.

KPI	Definition	Target	Frequency
SLA Compliance Rate	Percentage of vulnerabilities remediated within defined SLA	> 95%	Monthly
MTTR - Critical	Average days to close Critical vulnerabilities	< 3 days	Monthly
MTTR - High	Average days to close High vulnerabilities	< 7 days	Monthly
Open Critical Vulnerabilities	Number of Critical vulnerabilities open beyond SLA	0	Weekly
Vulnerability Recurrence Rate	Percentage of vulnerabilities that reappear after closure	< 5%	Quarterly
Escalation Rate	Percentage of vulnerabilities requiring CISO escalation	< 10%	Monthly

SECTION 8

Document Control

Document Title	Cryptographic Vulnerability Management Process
Document Owner	Cryptography Security Analyst
Programme	Enterprise Cryptographic Risk Management Program
Version	1.0
Status	For Internal Review
Created	04 June 2026
Review Frequency	Annually or following a major cryptographic incident
Next Review Date	April 2027
Approved By	CISO (Pending Approval)

Version History

Version	Date	Author	Changes
1.0	04 June 2026	Cryptography Security Analyst	Initial draft